

Clase 212 — Forense en la nube

Parte: **9 — Forense digital y respuesta a incidentes** · Fuente: *NIST IR 8006 — Cloud Computing Forensic Science Challenges* y documentación de AWS/Azure/GCP ·  Duración estimada: **120 min** · Nivel: **Avanzado**

Objetivo

Entender cómo cambia la forense cuando la evidencia vive en la nube: modelo de responsabilidad compartida, logs de plataforma (CloudTrail, Azure Activity Log, GCP Audit), snapshots de discos, y adquisición de instancias efímeras. Al terminar sabrás qué evidencia pedir, cómo preservarla y cómo investigar un compromiso de identidad en la nube.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Explicar** cómo el modelo de responsabilidad compartida afecta la evidencia.
2. **Identificar** las fuentes de logs forenses en AWS, Azure y GCP.
3. **Adquirir** evidencia mediante snapshots y exportación de logs.
4. **Investigar** un compromiso de credenciales/identidad en la nube.
5. **Preservar** evidencia efímera antes de que desaparezca.

Temas

#	Tema	Por qué importa
1	Responsabilidad compartida	Define a qué evidencia accedes
2	CloudTrail y logs de control	Historial de acciones de API
3	Azure Activity/Sign-in Logs	Equivalente en Azure
4	GCP Audit Logs	Equivalente en GCP
5	Snapshots de disco	Adquisición de volúmenes
6	Instancias efímeras y contenedores	Evidencia que se evapora
7	Compromiso de identidad (IAM)	Vector dominante en nube
8	Preservación y aislamiento	Congelar la escena

Definiciones y características

- **Responsabilidad compartida:** el proveedor asegura la infraestructura; el cliente, sus datos y configuración. Característica: no tienes acceso al hipervisor ni al hardware.

- **CloudTrail (AWS):** registro de todas las llamadas a la API. Característica: la fuente forense primaria en AWS.
- **Azure Activity Log / Sign-in Log:** acciones sobre recursos e inicios de sesión de identidad. Característica: separan plano de control y autenticación.
- **GCP Audit Logs:** Admin Activity, Data Access, System Event. Característica: Data Access puede estar desactivado por costo.
- **Snapshot:** copia puntual de un volumen. Característica: método estándar de adquisición de disco en nube.
- **Evidencia efímera:** instancias/contenedores que se destruyen al escalar. Característica: hay que capturarla antes del *terminate*.
- **Rol/clave IAM comprometida:** credencial robada usada por el atacante. Característica: se investiga por patrones anómalos en los logs de API.

Herramientas y preparación

- **AWS:** consola de CloudTrail, `aws cloudtrail lookup-events`, snapshots EBS, herramientas como `Prowler` para revisar configuración.
- **Azure:** Activity Log, Microsoft Sentinel, KQL.
- **GCP:** Cloud Logging, `gcloud logging read`.
- **Entorno:** usa una cuenta/proyecto PROPIO (nivel gratuito). Nunca investigues cuentas ajenas sin autorización.

Laboratorio guiado

Usa tu propia cuenta de nube en nivel gratuito. Simula el "incidente" tú mismo.

1. Genera actividad de prueba y consúltala en CloudTrail (AWS):

```
bash aws cloudtrail lookup-events --lookup-attributes
AttributeKey=EventName,AttributeValue=RunInstances
```

2. Busca acciones sospechosas por identidad:

```
bash aws cloudtrail lookup-events --lookup-attributes
AttributeKey=Username,AttributeValue=usuario-prueba
```

3. Adquiere evidencia de un volumen creando un snapshot:

```
bash aws ec2 create-snapshot --volume-id vol-0123456789 --description "Evidencia CASO-2026-01"
```

4. Aísla la instancia comprometida cambiando su security group a uno sin tráfico (sin apagarla, para no perder RAM).
5. En Azure, consulta inicios de sesión sospechosos en el Sign-in Log con KQL:

```
kql SigninLogs | where ResultType != 0 | project TimeGenerated, UserPrincipalName, IPAddress, ResultDescription
```

6. En GCP, exporta logs de auditoría:

```
bash gcloud logging read 'logName:"cloudaudit.googleapis.com"' --limit 50 --format json
```

7. Reconstruye el compromiso: identifica la credencial usada, la IP de origen, las acciones realizadas y los recursos afectados.
8. Preserva: exporta los logs relevantes a un bucket con *object lock* / retención para que no se alteren.

Ejercicios

1. Explica qué evidencia NO puedes obtener por la responsabilidad compartida.
2. Consulta en CloudTrail las últimas 24 h de acciones de una identidad.
3. Crea un snapshot de un volumen propio como evidencia.
4. Detecta un login desde IP inusual en Azure Sign-in Logs.
5. Exporta logs de auditoría de GCP a formato analizable.
6. Diseña un procedimiento para aislar una instancia sin perder RAM.

Reto verificable

En tu cuenta de nube, simula un compromiso de credenciales (una clave IAM que "un atacante" usa desde otra sesión) y reconstruye, solo desde los logs de la plataforma, qué hizo, cuándo y desde dónde, preservando la evidencia de forma inmutable.

Criterio de aceptación: entregas un informe con la credencial comprometida, la línea de tiempo de sus acciones (con marcas UTC), la IP de origen, los recursos afectados y la prueba de que los logs de evidencia quedaron con retención/inmutabilidad.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
CloudTrail no tiene el evento	Trail no configurado para esa región/servicio. Habilita un trail multi-región.
Data Access logs vacíos en GCP	Desactivados por costo. Actívalos antes del incidente.
Snapshot no monta	Falta adjuntarlo a una instancia forense. Crea un volumen desde el snapshot.
Apagaste la instancia y perdiste RAM	Aísla por red, no por apagado, si quieres la memoria.
Logs alterables	Sin retención/inmutabilidad. Usa object lock o cuenta de logging separada.

Preguntas frecuentes

? ¿Qué evidencia no tengo en la nube? El hipervisor, el hardware y la red física del proveedor. Trabajas con lo que las APIs y logs exponen.

? ¿Cómo capturo una instancia efímera? Antes de que se destruya: snapshot del disco y, si puedes, volcado de memoria vía agente. Automatiza la captura ante alerta.

? **¿CloudTrail lo registra todo?** Registra llamadas a la API (plano de control). Data events (S3, Lambda) y logs de aplicación requieren configuración adicional.

? **¿Cómo preservó logs para que no se borren?** Exporta a almacenamiento con retención/inmutabilidad (object lock) o a una cuenta/proyecto de logging aislado.

Referencias

- NIST IR 8006 — Cloud Forensic Science Challenges:
<https://csrc.nist.gov/publications/detail/nistir/8006/final>
- AWS CloudTrail: <https://docs.aws.amazon.com/cloudtrail/>
- Azure Monitor / Sign-in logs: <https://learn.microsoft.com/azure/azure-monitor/>
- GCP Cloud Audit Logs: <https://cloud.google.com/logging/docs/audit>

Siguiente clase

Clase 213 - Anti-forense y sus contramedidas